SPIKA TECH™

PROCEDIMIENTO DE ANÁLISIS Y GESTIÓN DE RIESGOS

HISTORIAL DEL DOCUMENTO			
Versión	**Resumen de modificaciones**	**Fecha de entrada**	**Sustituye a (Código, revisión)**
01	Primera versión del documento.	26/02/2025	N/A

REGISTRO DE FIRMAS			
Función:	**Elaborado por:**	**Revisado por:**	**Aprobado por:**
Departamento:	Responsable del SGSI	Dirección	Jefe de seguridad (o suplente)
Nombre:	David Pozo	Carlos Rodrigo	Carlos Zúñiga
Firma:	Firmado por POZO SANCHEZ DAVID - ***6992** el día 26/02/2025	Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) el día 26/02/2025	Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 26/02/2025 con un
Fecha:	26/02/2025	26/02/2025	26/02/2025

CONTENIDO

1 OBJETIVO 4
2 ALCANCE 4
3 NORMATIVA APLICABLE 4
4 METODOLOGÍA DE GESTIÓN DE RIESGOS 5
4.1.1 ANÁLISIS DE RIESGOS 7
4.1.2 IDENTIFICACIÓN E INVENTARIO DE ACTIVOS 7
4.1.3 DEPENDENCIAS ENTRE ACTIVOS 8
4.1.4 VALORACIÓN DE ACTIVOS 10
4.1.5 IDENTIFICACIÓN Y VALORACIÓN DE AMENAZAS 12
4.1.6 ESTIMACIÓN, FRECUENCIA Y DEGRADACIÓN DE LOS ACTIVOS 13
4.1.7 SELECCIÓN Y EVALUACIÓN DE LAS SALVAGUARDAS 15
4.1.8 DETERMINACIÓN DEL RIESGO 16
4.1.9 NIVEL DE ACEPTACIÓN DEL RIESGO 17
4.1.10 PLAN DE TRATAMIENTO DEL RIESGO 19
4.1.11 INFORME DE ANÁLISIS DE RIESGOS 21
4.1.12 MONITORIZACIÓN Y REVISIÓN DEL ANÁLISIS DE RIESGOS 21
5 REGISTROS Y ARCHIVOS 22
6 REFERENCIAS 22

1 OBJETIVO

El objetivo de este procedimiento es describir el proceso a seguir para la realización del análisis de riesgos, conforme a los requisitos establecidos por la ISO 27001:2022.

El análisis de riesgos se adaptará a la categoría del sistema según se establece en la propia norma se realizará usando un lenguaje específico, con un catálogo de amenazas y una semántica definida. Es decir, una presentación con tablas que describa los siguientes aspectos:

- Identifique y valore cualitativamente los activos más valiosos del sistema.
- Identifique y cuantifique las amenazas más probables.
- Identifique y valore las salvaguardas que protegen de dichas amenazas.
- Identifique y valore el riesgo residual.

Para la realización del análisis de riesgos se utilizará la metodología MAGERIT.

Este procedimiento servirá para determinar el mapa de riesgos a los que se está expuesto, así como para establecer los mecanismos y pasos a dar para el tratamiento de los mismos.

2 ALCANCE

Este Procedimiento de seguridad TIC es de aplicación, con carácter obligatorio, sobre todos los sistemas TIC responsabilidad de SPIKA TECH, servicios y procesos de negocio, activos de información y sus dependencias, personal interno o externo que tenga acceso información o sistemas del SPIKA TECH (con independencia de que exista o no una relación de carácter laboral) y, cualquier otra entidad involucrada con SPIKA TECH en la utilización de su información y sus sistemas.

3 NORMATIVA APLICABLE

Es aplicable toda la normativa establecida en el documento de **RGS_1 NORMATIVA APLICABLE.xlsx.**, que se actualizara de forma periódica Las Políticas, Normas y Procedimientos dentro del alcance del SGSI, se actualizarán, si procede, en base a los cambios normativos que pudieran afectar.

4 METODOLOGÍA DE GESTIÓN DE RIESGOS

Para la realización del análisis de riesgos se utilizará la metodología MAGERIT - metodología de análisis y gestión de riesgos elaborada por el Consejo Superior de Administración Electrónica. MAGERIT figura en el inventario de métodos de análisis y gestión de riesgos de ENISA en http://rminv. enisa.europa.eu/methods_tools/m_magerit.html.

Esta metodología permite:

- Estudiar los riesgos que soporta un sistema de información y el entorno asociado a él. MAGERIT propone la realización de un análisis de los riesgos que implica la evaluación del impacto que una violación de la seguridad tiene en la organización; señala los riesgos existentes, identificando las amenazas que acechan al sistema de información, y determina la vulnerabilidad del sistema de prevención de dichas amenazas, obteniendo unos resultados.
- El sistema se modela por medio de la identificación de los activos que lo componen. Los activos están expuestos a una serie de amenazas, y vulnerabilidades bajo las que podrían actuar dichas amenazas, que, cuando ocurren, degradan el [valor del] activo, causando un cierto impacto. Si estimamos la probabilidad de la amenaza, podemos concluir el riesgo en el sistema, o la pérdida a la cual está expuesto. Por su parte, la degradación y la probabilidad califica la vulnerabilidad del sistema frente a una amenaza.
- Los resultados del análisis de riesgos permiten a la gestión de riesgos, recomendar las medidas apropiadas que deberían adoptarse para conocer, prevenir, impedir, reducir o controlar los riesgos identificados y así reducir al mínimo su potencialidad o sus posibles perjuicios.
- Una vez conocidos los riesgos más críticos, SPIKA TECH tiene la oportunidad de desplegar salvaguardas o controles para hacer frente a las amenazas. Las salvaguardas mitigan los valores de impacto y riesgo dejándolos reducidos a unos valores residuales.

Se utilizará una herramienta propia, que implementa la metodología MAGERIT de análisis y gestión de riesgos.

En la figura que se muestra a continuación se indica lo descrito anteriormente de manera gráfica.

Con la aplicación de esta metodología se persiguen los siguientes objetivos:

Directos:

- Concienciar a los diferentes responsables en el SPIKA TECH de la existencia de riesgos y de la necesidad de gestionarlos.
- Ofrecer un método sistemático para analizar los riesgos derivados del uso de TIC.
- Ayudar a descubrir y planificar el tratamiento oportuno para mantener los riesgos bajo control.

Indirectos:

- Preparar a SPIKA TECH para procesos de evaluación, auditoría, certificación o acreditación, según corresponda en cada caso.
- También se ha buscado la uniformidad de los informes que recogen los hallazgos y las conclusiones de las actividades de análisis y gestión de riesgos.

El Análisis de Riesgos consiste en identificar y valorar los riesgos a los que están sometidos los activos de nuestro sistema. Los pasos a seguir en el Análisis de Riesgos son los siguientes:

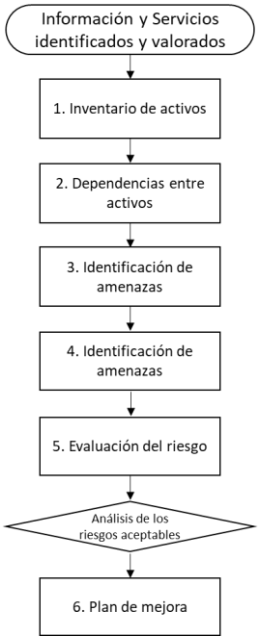
- Determinar los activos relevantes para SPIKA TECH, su interrelación y su valor, en el sentido de qué perjuicio (coste) supondría su degradación.
- Determinar a qué amenazas están expuestos aquellos activos.

- Determinar qué salvaguardas hay dispuestas y cuán eficaces son frente al riesgo.
- Estimar el impacto, definido como el daño sobre el activo derivado de la materialización de la amenaza.
- Estimar el riesgo, definido como el impacto ponderado con la tasa de ocurrencia (o expectativa de materialización) de la amenaza.

4.1.1 ANÁLISIS DE RIESGOS

Uno de los requisitos de mayor importancia que se establece a nivel de seguridad de la información y continuidad del negocio para su cumplimiento es la realización de un análisis de los riesgos a los que está sometida la organización. En dicho Análisis de Riesgos se valoran las salvaguardas/medidas, para así obtener unos resultados más ajustados a la realidad y con el objetivo de identificar a posteriori medidas adicionales que permitan reducir, en la medida de lo posible, los niveles de riesgos por debajo de los límites de aceptación previamente definidos.

El proceso se resume en el siguiente gráfico:



4.1.2 IDENTIFICACIÓN E INVENTARIO DE ACTIVOS

Un sistema de información presenta dos activos esenciales:

- La información que maneja.
- Los servicios que presta.

Estos activos esenciales marcan los requisitos de seguridad para todos los demás componentes del sistema.

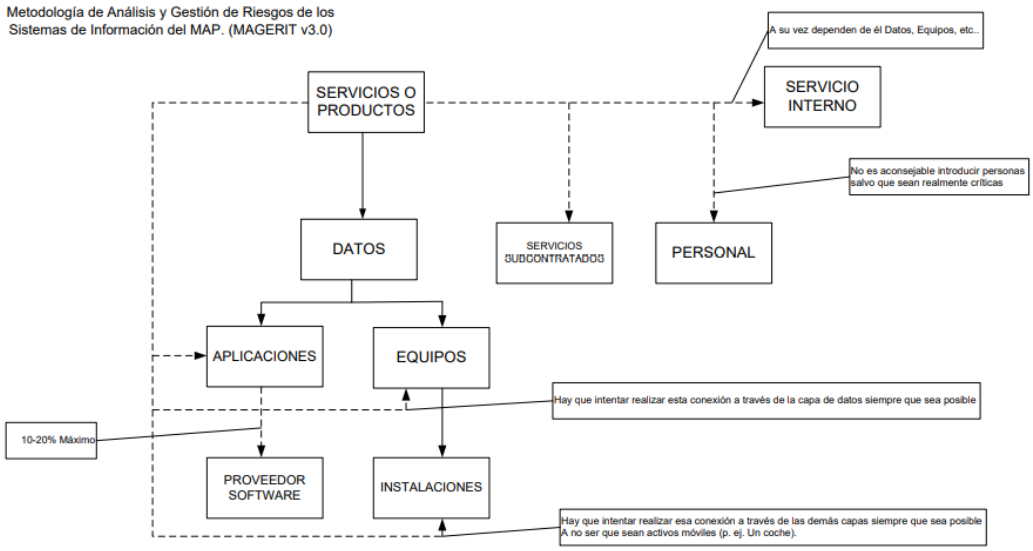
Se ha realizado una identificación e inventariado de todos los activos que son necesarios para los servicios dentro del alcance. Para ello, se ha seguido la división de activos propuesta por MAGERIT v3.

El inventario de activos de SPIKA TECH se realiza estableciendo tres capas principales:

- Activos esenciales. Información que se maneja y servicios que se prestan en la organización, ya sea de manera interna o a través de proveedores externos.
- Capa de Aplicación. Incluye sistemas de información, aplicativos, bases de datos, etc.
- Capa de Tecnología e Instalaciones. Incluye hosts y servidores, clusters, sistemas de almacenamiento y recursos de red, appliances, routers y switches, puestos de trabajo, teléfonos móviles, CPD, SAI, sistemas de refrigeración, etc.

4.1.3 DEPENDENCIAS ENTRE ACTIVOS

Tras la identificación de los activos, se realiza un estudio de dependencias entre los mismos, de modo que cada nivel tiene dependencias respecto a los niveles inferiores, comenzando por los servicios esenciales (servicio de negocio) y por el nivel de Información/Datos.



Basándose en el esquema anterior para la construcción de las dependencias entre los activos, se ha procedido a la definición de las dependencias entre los activos identificados y necesarios para la gestión de los servicios TI dentro del alcance.

Se pueden identificar otros activos relevantes dependientes de los activos esenciales:

- Datos que materializan la información.
- Servicios auxiliares que se necesitan para poder organizar el sistema.
- Las aplicaciones informáticas (software) que permiten manejar los datos.
- Los equipos informáticos (hardware) y que permiten hospedar datos, aplicaciones y servicios.
- Los soportes de información que son dispositivos de almacenamiento de datos.
- El equipamiento auxiliar que complementa el material informático.
- Las redes de comunicaciones que permiten intercambiar datos.
- Las instalaciones que acogen equipos informáticos y de comunicaciones.
- Las personas que explotan u operan todos los elementos anteriormente citados.
- No todos los activos son de la misma especie.

Dependiendo del tipo de activo, las amenazas y las salvaguardas son diferentes. El objetivo de la identificación de las relaciones de dependencia entre activos es identificar y valorar dichas dependencias. Se dice que un “activo superior” depende de otro “activo inferior” cuando las necesidades de seguridad del superior se reflejan en las necesidades de seguridad del

inferior. O, dicho en otras palabras, cuando la materialización de una amenaza en el activo inferior tiene como consecuencia un perjuicio sobre el activo superior.

Informalmente puede interpretarse que los activos inferiores son los pilares en los que se apoya la seguridad de los activos superiores. El resultado es una red de dependencias entre activos.

De acuerdo con la definición de dependencia descrita, conviene matizar según cada caso el grado de dependencia entre los activos (Peso de las dependencias). Para homogeneizar criterios, se establece la siguiente tabla:

Dependencia	Descripción
100%	Total. La criticidad de los activos se transmite enteramente a los activos inferiores. Los activos superiores dependen totalmente de los inferiores.
90%	Muy alta. La criticidad de los activos se transmite casi enteramente a los activos inferiores. Los activos superiores dependen casi totalmente de los inferiores.
50%	Alta. La criticidad de los activos se transmite parcialmente a los activos inferiores. Los activos superiores dependen en cierto sentido de los inferiores, si bien, no en su totalidad.
10%	Media. Una pequeña parte de la criticidad de los activos se transmite a los activos inferiores. Alguna parte o función menor de los activos superiores depende de los inferiores, si bien, el riesgo que pueden transmitir es bajo.
1%	Baja. La dependencia es en ambos sentidos mínima, si bien, existente.
0%	No existe dependencia entre los activos.

La identificación de activos, dependencias, valoración y las dimensiones afectadas se realizarán de acuerdo a lo indicado en MAGERIT.

4.1.4 VALORACIÓN DE ACTIVOS

Una vez definidas las relaciones entre todos los activos, se procede a introducir la valoración cualitativa de los activos de Información y Servicios realizada, comparando los mismos con relación a su importancia en SPIKA TECH. Se asigna, por tanto, una valoración relativa entre los mismos (de 0 a 10) dependiendo de su criticidad según los criterios de valoración definidos en MAGERIT.

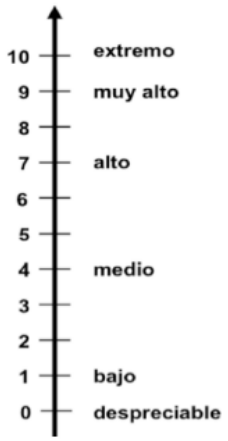
Esta valoración será imputada (heredada) a todos los activos dependientes de la Información y de los Servicios respectivamente y se conoce como valor acumulado o heredado. La valoración se realiza habitualmente desde la perspectiva de la “necesidad de proteger”, ya que cuanto más valioso es un activo, mayor nivel de protección requeriremos en la dimensión (o dimensiones) de seguridad que apliquen.

El servicio de SPIKA TECH objeto del alcance del presente análisis de riesgos, se ha valorado atendiendo a lo dispuesto en la metodología MAGERIT.

Esta valoración por activo se realiza atendiendo a las siguientes dimensiones según MAGERIT:

- **Disponibilidad [D]:** consecuencias que tendría el que una persona autorizada no pudiera acceder al servicio cuando lo necesita.
- **Integridad [I]:** consecuencias que tendría la modificación o alteración de la información asociada al servicio por alguien que no está autorizado a modificarlo.
- **Confidencialidad [C]:** consecuencias que tendría la revelación de información del servicio a personas no autorizadas o que no necesitan conocerla. La valoración se realiza habitualmente desde la perspectiva de la “necesidad de proteger”, pues cuanto más valioso es un activo, mayor nivel de protección requeriremos en la dimensión (o dimensiones) de seguridad que sean pertinentes.

Por tanto, para determinar la valoración de las dimensiones de seguridad se ha utilizado la siguiente tabla de valoración:



valor		*criterio*
10	extremo	daño extremadamente grave
9	muy alto	daño muy grave
6-8	alto	daño grave
3-5	medio	daño importante
1-2	bajo	daño menor
0	despreciable	irrelevante a efectos prácticos

4.1.5 IDENTIFICACIÓN Y VALORACIÓN DE AMENAZAS

La caracterización de las amenazas consiste en identificar las amenazas que acechan a los activos y la vulnerabilidad ante esas amenazas en términos de probabilidad y degradación.

De este modo, es posible estimar el impacto y riesgo potencial o intrínseco sobre cada uno de los activos. La diversidad de causas permite clasificarlas según su naturaleza en función de su origen:

- **De origen natural [N]:** Sucesos que pueden ocurrir sin intervención de los seres humanos como causa directa o indirecta como, por ejemplo, accidentes naturales como terremotos e inundaciones. Ante esos avatares el sistema de información es víctima pasiva, pero siempre debe tenerse en cuenta lo que puede suceder.
- **Del entorno (de origen industrial) [I]:** Sucesos que pueden ocurrir de forma accidental, derivados de la actividad humana de tipo industrial. Estas amenazas pueden darse de forma accidental o deliberada, como, por ejemplo, desastres industriales como contaminación o fallos eléctricos, ante los cuales el sistema de información es víctima pasiva; pero no por ser pasivos hay que permanecer indefensos.
- **Errores y fallos no intencionados [E]:** Fallos no intencionales causados por las personas, como, por ejemplo, defectos de las aplicaciones y problemas que nacen directamente en el equipamiento propio por defectos en su diseño o en su implementación, con consecuencias potencialmente negativas sobre el sistema.
  Frecuentemente se denominan vulnerabilidades técnicas o, simplemente, vulnerabilidades. También las causadas por las personas de forma accidental, como, por ejemplo, personas con acceso al sistema de información que pueden ser causa de problemas no intencionados, típicamente por error o por omisión.
- **Ataques intencionados [A]:** Fallos deliberados causados por las personas, como, por ejemplo, personas con acceso al sistema de información que pueden ser causa de problemas intencionados, lo que se traduce en ataques deliberados; bien con ánimo de beneficiarse indebidamente, bien con ánimo de causar daños y perjuicios a los legítimos propietarios.

No todas las amenazas afectan a todos los activos, sino que hay una cierta relación entre el tipo de activo y lo que le podría ocurrir.

Cuando un activo es víctima de una amenaza, no se ve afectado en todas sus dimensiones, ni en la misma cuantía.

Se seleccionarán los eventos de amenaza para cada activo en base al catálogo de amenazas de la metodología MAGERIT (apartado 5 del “Libro II - Catálogo de Elementos”) y en función del tipo de activo, ubicación, histórico de problemas y experiencias previas. Se aplicarán amenazas a nivel de información, equipamiento, instalaciones y servicios externos e internos.

4.1.6 ESTIMACIÓN, FRECUENCIA Y DEGRADACIÓN DE LOS ACTIVOS

Una vez determinado que una amenaza puede perjudicar a un activo, hay que valorar su influencia en el valor del activo, en dos sentidos:

- **Impacto:** cuán perjudicado resultaría el [valor del] activo.
- **Probabilidad:** cuán probable o improbable es que se materialice la amenaza o bien cada cuánto se materializa la amenaza.

La degradación mide el daño causado por un incidente en el supuesto de que ocurriera. La degradación se suele caracterizar como una fracción del valor del activo y así aparecen expresiones como que un activo se ha visto “totalmente degradado”, o “degradado en una pequeña fracción”.

Cuando las amenazas no son intencionales, probablemente baste conocer la fracción físicamente perjudicada de un activo para calcular la pérdida proporcional de valor que se pierde. Pero cuando la amenaza es intencional, no se puede pensar en proporcionalidad alguna pues el atacante puede causar muchísimo daño de forma selectiva.

Para el análisis de riesgos se propone la utilización de los siguientes valores, junto con una interpretación de su significado:

Dependencia	Descripción
100%	El activo queda totalmente inutilizado, causando un daño excepcional sobre su misión para la Organización.
90%	El activo ha sufrido importantes daños, que muy probablemente tengan serias repercusiones sobre su misión en la organización.
50%	Aunque la degradación ha sido importante, el activo (o un respaldo suyo) puede seguir funcionando.
10%	Se producen daños en el activo que pueden causar pérdidas menores o mermas en la seguridad sobre ciertos aspectos.
1%	La degradación sería causa de inconveniencias mínimas sobre la Organización.

La frecuencia pone en perspectiva la degradación. Una amenaza puede ser de terribles consecuencias, pero de muy improbable materialización y, por el contrario, una amenaza puede ser de muy bajas consecuencias, pero tan frecuente como para acabar acumulando un daño considerable. Para los análisis, la frecuencia se modelará como una tasa anual de ocurrencia, siendo los valores recomendables y sus significados los siguientes:

Frecuencia	Descripción
CS- Casi Seguro	Muy frecuente. A diario
MA – Muy Alto	Frecuente. Mensualmente
P- Posible	Normal. Más de una vez al año
PP – Poco Probable	Una vez cada al año
MR- Muy Rara	Poco frecuente. Cada 5 años
0	No ocurre

Atendiendo a los distintos grupos de amenazas identificados, se puede decir en líneas generales que:

- **Desastres naturales**. Son de muy poca frecuencia, pero causan grandes daños sobre los activos (normalmente su destrucción total).
- **De origen industrial.** Algunas de ellas causan daños muy graves, con una frecuencia algo mayor que los desastres naturales. Algunas pueden llegar a tener una frecuencia anual con impactos importantes, por lo que es vital tratarlas correctamente.

- **Errores y fallos no intencionados.** Algunas de ellas pueden ser muy frecuentes, si bien su impacto no suele ser alto, existiendo controles relativamente sencillos para mitigarlas. Por su alta frecuencia, requieren ser tenidas muy en consideración.
- **Ataques intencionados.** Son difíciles de predecir y su frecuencia e impacto pueden ser altos.

Los valores de degradación y frecuencia se tomarán a partir de la combinación de dos fuentes de conocimiento principales:

- La experiencia previa acumulada en la realización de análisis de riesgos.
- El análisis del entorno de SPIKA TECH

La valoración de las amenazas (determinación de la frecuencia y degradación sobre el activo provocado por la materialización de las amenazas sobre estos), se realiza en la propia herramienta utilizada.

4.1.7 SELECCIÓN Y EVALUACIÓN DE LAS SALVAGUARDAS

Se definen las salvaguardas o contramedidas como aquellos procedimientos o mecanismos tecnológicos que reducen el riesgo.

Ante el amplio abanico de posibles salvaguardas a considerar, es necesario hacer una criba inicial para quedarse con aquellas que son relevantes para lo que hay que proteger. En esta criba se deben tener en cuenta los siguientes aspectos:

- Tipo de activos a proteger, pues cada tipo se protege de una forma específica.
- Dimensión o dimensiones de seguridad que requieren protección.
- Amenazas de las que necesitamos protegernos.
- Si existen salvaguardas alternativas.

Además, es prudente establecer un principio de proporcionalidad y tener en cuenta:

- El mayor o menor valor propio o acumulado sobre un activo, centrándonos en lo más valioso y obviando lo irrelevante.
- La mayor o menor probabilidad de que una amenaza ocurra, centrándonos en los riesgos más importantes (ver zonas de riesgo).
- La cobertura del riesgo que proporcionan salvaguardas alternativas.

Esto lleva a dos tipos de declaraciones para excluir una cierta salvaguarda del conjunto de las que conviene analizar:

- no aplica – se dice cuando una salvaguarda no es de aplicación porque técnicamente no es adecuada al tipo de activos a proteger, no protege la dimensión necesaria o no protege frente a la amenaza en consideración.
- no se justifica – se dice cuando la salvaguarda aplica, pero es desproporcionada al riesgo que tenemos que proteger.

Como resultado de estas consideraciones se dispondrá de una “declaración de aplicabilidad” o relación de salvaguardas que deben ser analizadas como componentes del sistema de protección.

Las salvaguardas se caracterizan, además de por su existencia, por su eficacia frente al riesgo que pretenden mitigar. Las escalas de valoración de la efectividad son variadas, siendo comúnmente aceptado el Modelo de Madurez de la Capacidad (CMM).

CMM	DESCRIPCIÓN	Efectividad
L0	Inexistente	0%
L1	Inicial / Ad hoc	10%
L2	Reproducible, pero intuitivo	50%
L3	Proceso definido	90%
L4	Gestionado y medible	95%
L5	Optimizado	100%

Los resultados del nivel de cumplimiento se tomarán a partir de la información recabada en las entrevistas con el personal (responsables de los activos, personal técnico, etc.).

4.1.8 DETERMINACIÓN DEL RIESGO

El riesgo se define como el daño probable sobre un sistema conociendo el impacto de las amenazas sobre los activos y teniendo en cuenta la frecuencia de materialización de las amenazas. Al igual que el impacto, se distingue riesgo acumulado (riesgo intrínseco) y riesgo repercutido:

- Para el cálculo del riesgo acumulado se debe tener en cuenta el impacto acumulado sobre un activo y la frecuencia de la amenaza. Se calcula para cada activo, por cada amenaza y en cada dimensión de valoración, siendo una función del valor acumulado, de la degradación causada y la frecuencia de materialización de la amenaza.
- Para el cálculo del riesgo repercutido se debe tener en cuenta el impacto repercutido sobre un activo y la frecuencia de la amenaza. Se calcula para cada activo, por cada amenaza y en cada dimensión de valoración, siendo una función del valor propio, de la degradación causada y de la frecuencia de la materialización de la amenaza.

4.1.9 NIVEL DE ACEPTACIÓN DEL RIESGO

Se deberá determinar el nivel de impacto y riesgo aceptable que se pueda asumir. Una vez valorado el riesgo existente, para controlar y gestionar dicho riesgo, SPIKA TECH definirá los criterios que permitan conocer el umbral del riesgo, es decir, cuándo considera que el nivel de riesgo obtenido es aceptable, y cuándo es necesario actuar sobre el mismo.

Se plasmará en un documento independiente, un resumen del riesgo, el nivel de riesgo que se considera aceptable y el plan de tratamiento necesario para alcanzar el nivel de riesgo aceptable y que será el que presenta el sistema en el escenario “objetivo”.

A partir de los resultados de la evaluación de riesgos y teniendo en cuenta el umbral de riesgo establecido, se establecerán acciones que protejan efectivamente contra los riesgos no asumibles.

Estas acciones están enfocadas a:

- Reducir el riesgo implantando nuevos controles o mejorando los ya existentes.
- Evitar el riesgo modificando o eliminando el activo o la amenaza.
- Transferir el riesgo a terceros (seguros, proveedores, etc.).

Para ello se ha establecido los siguientes criterios de aceptación de riesgos y están asociados a:

Criterios de Aceptación del Riesgo (CAR)	
Daños irrelevantes	• Presente una afectación irrelevante para la prestación de los Servicios TIC.
Daño menor	• Probabilidad menor de afectar a un grupo de individuos • Probabilidad menor de causar incumplimiento leve o técnico de una ley o regulación. • Probabilidad menor de causar interrupción de actividades claves de los Servicios TIC. • Probabilidad menor de afectación en la operación efectiva de los Servicios TIC.
Daño importante	• Probablemente afecte a un grupo de individuos claves. • Probablemente quebrante leyes o regulaciones claves, que implican sanciones. • Probablemente cause incumplimiento leve y técnico de una ley o regulación claves. • Probablemente cause fallos que impliquen la degradación del servicio o actividades, pero permitiría mantener el servicio.
Daño grave	• Afecta a la totalidad de individuos del Servicio TIC. • Quebranta leyes o regulaciones claves. • Incumplimiento de una ley o regulación clave. • Cause paradas y/o degradación de servicio que provoque importantes retrasos en las actividades propias. • Impediría la operación total del servicio para el que se provee los Servicios TIC. • Perdida o inconsistencia de los datos.

En este sentido, trasladados estos criterios a los niveles de riesgo de la metodología se presentan los valores de riesgo varían entre 0 y 9 según la siguiente tabla:

Nivel Aceptación de Riesgo (NAR)		Criterios de Aceptación del Riesgo (CAR)		Acción
0	**despreciable**	Daños irrelevantes	• Presente una afectación irrelevante para la prestación de los Servicios TIC.	**Aceptar el riesgo**
1	**bajo**			**Aceptar el riesgo**
2	**medio**	Daños menores	• Presente una afectación irrelevante para la prestación de los Servicios TIC. • Probabilidad menor de causar incumplimiento leve o técnico de una ley o regulación. • Probabilidad menor de causar interrupción de actividades claves de los Servicios TIC.	**Aceptar el riesgo**
3	**alto**			**Aceptar el riesgo**

Nivel Aceptación de Riesgo (NAR)		Criterios de Aceptación del Riesgo (CAR)		Acción
			• Probabilidad menor de afectación en la operación efectiva de los Servicios TIC.	
4	**muy alto**	Daños importantes	• Presente una afectación irrelevante para la prestación de los Servicios TIC. • Probablemente quebrante leyes o regulaciones claves, que implican sanciones. • Probablemente cause incumplimiento leve y técnico de una ley o regulación claves. • Probablemente cause fallos que impliquen la degradación del servicio o actividades, pero permitiría mantener el servicio.	**No se aceptan,** Se deben establecer las acciones correspondientes para mitigar el riesgo y definir el Plan de Tratamiento del Riesgo (PTR).
5	**crítico**			
6	**muy crítico**			
7	**extremadamente crítico**	Daño grave	• Afecta a la totalidad de individuos del Servicio TIC. • Quebranta leyes o regulaciones claves. • Cause paradas y/o degradación de servicio que provoque importantes retrasos en las actividades propias. • Impediría la operación total del servicio para el que se provee los Servicios TIC. • Perdida o inconsistencia de los datos.	
8	**desastre**			
9	**catástrofe**			

Igualmente se debe tener en cuenta que los dominios de seguridad están interrelacionados, y las amenazas existentes en alguno de ellos pueden repercutir riesgos en el resto. Por ello puede haber riesgos residuales en los activos esenciales cuyo valor sea más alto que el riesgo de los activos que los componen, y esto se debe a los riesgos que les son repercutidos por el resto de los dominios.

Con base en los niveles descritos en la tabla anterior los niveles de aceptación de riesgo están comprendidos entre el 0 (despreciable) y 3 (alto), para cualquier riesgo por encima de lo antes indicado, se deberá definir medidas y Planes de Tratamiento del Riesgo (PTR), a fin de minimizar la exposición al riesgo.

4.1.10 PLAN DE TRATAMIENTO DEL RIESGO

En el Plan de Tratamiento de Riesgos se describirá para cada riesgo la decisión tomada:

- **Asumir:** no se realizarán acciones adicionales, sin embrago, se mantendrá un monitoreo constante del riesgo. Se tomarán medidas activas en función de que los riesgos se materialicen.
- **Reducir:** se definirán uno o más opciones para reducir el nivel de riesgo residual.

- **Transferir:** se definirán medidas para trasladar el riesgo a terceras partes a fin de que estos desarrollan opciones adicionales.
- **Eliminar:** Se tomará en cuenta que, para eliminar el riesgo, será necesario eliminar la fuente del riesgo.

Así como las actividades necesarias para la implantación de dicha decisión (implantación o mejora de controles, nuevas cláusulas de seguridad...) que palíen en la mayor medida posible el riesgo o por lo menos que el riesgo esté por debajo de los umbrales indicados cómo asumibles.

Tras el proceso de evaluación de riesgos siguiendo la metodología MAGERIT y los resultados obtenidos en la tabla de riesgos, el próximo paso consiste en establecer las medidas y controles de seguridad sobre los riesgos más elevados, es decir, aquellos que sean igual o estén por encima del nivel de riesgo aceptable {3,0}, con el objeto de mitigar dichos riesgos.

El objetivo final es obtener unos niveles inferiores al nivel de riesgo aceptable definido. Si dicho riesgo no puede minimizarse hasta los niveles óptimos, como último recurso se puede proceder a asumir el riesgo, siempre de forma justificada.

Para decidir el nivel de riesgo aceptable, se utilizará la técnica ALARP (As Low As Reasonably Possible), la cual es recomendada por la normativa ISO 31000 para la Gestión del Riesgo. Conforme a dicha técnica, el riesgo se clasifica en tres franjas o regiones:

- Ampliamente Aceptable: aquí se localizan los riesgos para los que el MTMS determina que son generalmente asumibles y no es necesario su tratamiento.
- Tolerable: riesgos que, en función de su naturaleza, del activo del que se trate, del tipo de amenaza, etc., deben ser evaluados de forma individual para determinar si deben ser considerados como “Ampliamente Aceptables” o “Inaceptables”.
- Inaceptable: riesgos para los que se considera que deben ser tratados (minimizados o mitigados mediante la implantación de controles, por ejemplo).

Dado que el análisis y gestión de riesgos es un proceso que debe repetirse cada ciclo anual, el nivel de riesgo inaceptable en el MTMS será igual o superior a {3,0}, el nivel de riesgo tolerable será inferior a {3,0} y superior a {1,5}, y el nivel ampliamente aceptable será para aquellos riesgos de nivel {1,5} o inferior.

Se le dará prioridad a aquellas acciones enfocadas a minimizar los riesgos que se consideren inaceptables (riesgos con nivel igual o superior a {3,0}).

Una vez se lleven a cabo las acciones identificadas en el plan de tratamiento de riesgos, aparecerán los riesgos residuales resultantes.

4.1.11 INFORME DE ANÁLISIS DE RIESGOS

El informe de análisis de riesgos contendrá como mínimo:

- La **relación de activos** más valiosos del sistema y su valoración.
- Las **amenazas más probables y su valoración.** En este apartado bastará un resumen de las principales, teniendo en cuenta que la relación de todas las amenazas y su valoración se podrán consultar directamente en la herramienta.
- La **identificación y valoración de las salvaguardas** que se encuentran implementadas por el sistema y que protegen de las amenazas identificadas.
- Se identificará y valorará el **riesgo residual**, presentando en **riesgo potencial**, el que tiene el sistema sin ninguna medida, y el **riesgo actual** del sistema, teniendo en cuenta las medidas de seguridad implementadas y el **riesgo objetivo**, una vez identificadas las medidas que será necesario implantar para alcanzar el escenario de objetivo.

4.1.12 MONITORIZACIÓN Y REVISIÓN DEL ANÁLISIS DE RIESGOS

Periódicamente se revisará el valor de los activos, impactos, amenazas, vulnerabilidades y probabilidades en busca de posibles cambios. para ello será necesario realizar una revisión al menos una vez al año o ante cambios significativos, como, por ejemplo:

- Cambios de arquitectura, equipos tecnológicos, procesamiento de la información.
- Cambios a nivel de recursos humanos, incluyendo la participación y/o cambios de proveedores.
- Cambios en las relaciones con las partes interesadas (internas y externas).

Los riesgos no son estáticos y pueden cambiar de forma radical sin previo aviso. Por ello es necesaria una supervisión continua que detecte:

- Nuevos activos o modificaciones en el valor de los activos.
- Nuevas amenazas.
- Cambios o aparición de nuevas vulnerabilidades.
- Aumento de las consecuencias o impactos.

- Incidentes de seguridad de la información.

Para conseguir una mejora continua se supervisará el estado actual y se realizarán las correcciones necesarias.

5 REGISTROS Y ARCHIVOS

	Nombre del registro	Versión y Modificaciones
REGISTRO	RGS_2 INVENTARIO DE ACTIVOS	

6 REFERENCIAS

- ISO 27001:2022:
  - 6.1 Acciones para tratar los riesgos y oportunidades.
    - 6.1.1. Consideraciones Generales
    - 6.1.2. Evaluación de los riesgos de seguridad de la información
    - 6.1.3. Tratamiento de los riesgos de seguridad de la información
  - 8.2. Evaluación de los riesgos de seguridad de la información
  - 8.3. Tratamiento de los riesgos de seguridad de la información